UNIVERSITY OF KELANIYA / SENG 34213

FOREVER HOTEL MANAGEMENT SYSTEM

OWASP Compliance Evidence

OWASP Top 10 (2021) Control Review | Six Subsystems

Reporting date: 9 November 2026. Evidence is identified by subsystem repository, branch, commit SHA, and GitHub Actions run date; comparisons across separate repository commits do not constitute a single deployed hotel-wide security certification.

Contents

1. Security evidence overview
2. Hotel Website (HW)
3. Manager Dashboard (MAD)
4. Front Desk System (FDS)
5. Food Ordering and Service Requests (FOSS)
6. Kitchen Management System (KMS)
7. Worker Management System (WKMS)
8. Outstanding security acceptance

---

1. Security evidence overview

Security controls across all six Forever Hotel subsystems and companion shared services (api-gateway, websocket-service, infra) are evaluated against the OWASP Top 10 (2021) categories A01 through A10 as of 9 November 2026. Passing unit, integration, and E2E security assertions demonstrate application-level controls within their tested boundaries; they do not substitute for a live staging TLS/WAF audit, independent penetration test, or production compliance certification.

Dependency-audit results and their scope (9 November 2026)

Hotel Website (forever-hotel/hotel-website)

In the committed HW OWASP checklist (commit 63673ba704, documents/owasp-checklist.pdf), raw full-tree npm audit --json recorded 4 backend advisories (3 high: @nestjs/platform-express, body-parser, multer; 1 moderate: fast-uri), 1 critical frontend advisory (next, fix available in 16.4.3), and 2 in-repo gateway advisories (1 moderate: fast-uri; 1 low: fastify). On develop (5e3cd6bf32, 9 November 2026), all backend, frontend, container, and staging CI checks pass, while full-tree dependency upgrades remain tracked as an explicit release gate.

Manager Dashboard & Shared Services (manager-dashboard, api-gateway, websocket-service)

REMEDIATED IN CI: The previous Manager Dashboard backend high-severity audit failure (body-parser, multer, qs) was resolved via package.json overrides on branch development (commit 8b2c63f459, Runs 42480400290 and 42504148805). Both backend (npm audit --audit-level=high) and frontend (npm run audit:ci) now pass with 0 high/critical vulnerabilities. In addition, the dedicated shared repositories forever-hotel/api-gateway (commit f12aad6cb4, Run 42504067779) and forever-hotel/websocket-service (commit f12ef41ba9, Run 42504249365) both pass npm audit --audit-level=high with 0 high/critical vulnerabilities.

Front Desk System (forever-hotel/front-desk)

REMEDIATED IN CI: The previous high-severity undici development dependency finding was remediated by upgrading undici to 8.12.2 (commit 1065617 on feature/84-fds-final-qa-evidence and merged into develop at 4b5ef57d4c, Runs 42506217082 and 42506217056). Backend high-threshold audit, frontend production-only audit, and full frontend npm audit all return 0 vulnerabilities.

Food Ordering and Service Requests (forever-hotel/food-ordering)

PASSING IN CI: On develop (commit 0d80cf5c66, Run 42490527447) and QA snapshot 9ac1e6f (Run 41833172660), the dedicated Dependency Security Scan CI job, Oxlint (240 backend files, 0 errors/warnings), and ESLint 9 (frontend, 0 errors/warnings) all pass with 0 high/critical vulnerabilities.

Kitchen Management System (forever-hotel/kitchen-management)

PASSING IN CI: On develop (commit 0eaf5ab, Run 42645080201), both backend and frontend npm run security:audit (npm audit --omit=dev --audit-level=high) pass with 0 vulnerabilities across production dependencies alongside 837 passing automated tests.

Worker Management System (forever-hotel/worker-management)

PASSING IN CI: On develop (commit 1a33059c00, Runs 42504698971 and 42504970394), both backend and frontend production high-threshold dependency audits pass with 0 vulnerabilities alongside 649 passing automated tests and Docker image verification.

Control coverage

All 60 subsystem/category combinations (six subsystems multiplied by ten OWASP Top 10 categories) are evaluated below, preserving verified source/test evidence and remaining staging or operational verification actions.

2. Hotel Website (HW)

Repository: forever-hotel/hotel-website | Branch: develop (merged PR #99 from pre-develop 440761c34a; QA package: 63673ba704b4ae645a8f067e246309b6fb0f03d0) | Tested revision: 5e3cd6bf323bc005e9efb86b5e09ba0e3015e727 | CI date: 9 November 2026

Evidence: https://github.com/forever-hotel/hotel-website/actions/runs/42504096480, https://github.com/forever-hotel/hotel-website/actions/runs/42504096452, https://github.com/forever-hotel/hotel-website/actions/runs/42500427127, documents/owasp-checklist.pdf (63673ba704)

Dependency position: Raw full-tree npm audit --json in documents/owasp-checklist.pdf (63673ba704) recorded 3 high + 1 moderate backend advisories (@nestjs/platform-express, body-parser, multer, fast-uri) and 1 critical frontend advisory (next, fix in 16.4.3); standalone forever-hotel/api-gateway (f12aad6cb4) passes npm audit --audit-level=high with 0 high/critical findings.

A01 Broken Access Control

Broken Access Control — PARTIALLY EVIDENCED: JWT guest guards and guest-scoped repositories enforce strict booking ownership; cross-guest read, modification, cancellation, and payment recovery attempts are verified in disposable PostgreSQL HTTP integration tests (returning 404 anti-enumeration responses rather than 403), and frontend returnTo validation blocks open redirects. Evidence: backend/src/common/guards/jwt-auth.guard.ts; backend/test/integration/http-consumer-contracts.integration-spec.ts (passing in Run 42504096480); frontend/tests/auth.test.mjs.

Required follow-up: Obtain reviewer sign-off on the 401/404 anti-enumeration contract and verify access controls on deployed staging.

A02 Cryptographic Failures

Cryptographic Failures — PARTIALLY EVIDENCED: Guest passwords use bcrypt cost 12; JWT tokens use timing-safe HMAC verification with 24h expiry; session cookies use HttpOnly and production Secure attributes; PayHere webhook notifications verify merchant HMAC signatures before payment reconciliation. Evidence: backend/src/guests/password-hasher.service.spec.ts; backend/src/common/utils/jwt-token.service.spec.ts; backend/src/payments/payhere-provider.spec.ts; frontend/src/features/auth/actions.ts.

Required follow-up: Verify staging HTTPS/TLS certificate configuration and secret rotation procedures.

A03 Injection

Injection — PARTIALLY EVIDENCED: SQL repositories use parameterized queries exclusively; NestJS ValidationPipe enforces strict DTO whitelisting and input bounds; React escapes rendered text; room catalogue and image utilities reject unsafe origins and malformed records. Evidence: backend/src/database/repositories/booking.repository.ts; backend/test/integration/http-consumer-contracts.integration-spec.ts; frontend/tests/rooms.test.mjs.

Required follow-up: Execute automated DAST/fuzzing scans against deployed staging routes.

A04 Insecure Design

Insecure Design — PARTIALLY EVIDENCED: Signed change previews bind guest identity, booking state, and revision; competing final-room reservations use sorted row locks verified by a two-guest concurrent PostgreSQL race test (booking-race.integration-spec.ts passing in Run 42504096480); client redirect parameters cannot confirm unpaid bookings (TC-HW-11-02, TC-SEC-03). Evidence: backend/src/bookings/booking-management.service.spec.ts; backend/test/integration/booking-race.integration-spec.ts; frontend/tests/payment.test.mjs; deploy/staging/test/smoke.test.mjs.

Required follow-up: Complete live MAD promotion redemption and live PayHere sandbox callback verification.

A05 Security Misconfiguration

Security Misconfiguration — PARTIALLY EVIDENCED: Production configuration disables Swagger and rejects DB_LOGGING=true (TC-SEC-02) and schema synchronization; AllExceptionsFilter returns generic client errors without leaking stack traces, SQL, or secrets (TC-SEC-01); container CI verifies 503 readiness behavior during PostgreSQL outage. Evidence: backend/src/config/env.validation.spec.ts; backend/src/common/filters/all-exceptions.filter.spec.ts; .github/workflows/container-checks.yml (Run 42504096444).

Required follow-up: Verify deployed reverse-proxy security headers (CSP, HSTS), container hardening, and vault secret injection.

A06 Vulnerable and Outdated Components

Vulnerable and Outdated Components — OPEN FINDINGS (TRACKED): Raw npm audit --json in documents/owasp-checklist.pdf (63673ba704) identified 3 high backend transitive package findings (@nestjs/platform-express, body-parser, multer), 1 moderate backend finding (fast-uri), and 1 critical frontend advisory (next, fix available in 16.4.3). Evidence: backend/package-lock.json; frontend/package-lock.json; documents/owasp-checklist.pdf.

Required follow-up: Apply compatible Next.js and NestJS/Express transitive dependency upgrades (matching the overrides applied in MAD), rerun full test and browser suites, and enforce a blocking CI audit gate.

A07 Identification and Authentication Failures

Identification and Authentication Failures — PARTIALLY EVIDENCED: Generic unauthorized responses prevent email enumeration (TC-HW-016); expired/tampered JWTs are rejected; contact enquiry endpoint enforces per-IP rate limiting (TC-HW-16-02); API Gateway enforces per-process login rate limiting. Evidence: backend/test/integration/guest-auth.integration-spec.ts; backend/src/contact/contact-rate-limit.guard.spec.ts; api-gateway/src/app.ts.

Required follow-up: Implement account-based lockout after repeated failed logins and evaluate token revocation/distributed throttling.

A08 Software and Data Integrity Failures

Software and Data Integrity Failures — PARTIALLY EVIDENCED: CI uses npm ci with committed lockfiles; staging release tooling enforces digest-pinned immutable images and automatic rollback to the previous image pair on health/smoke failure (TC-DEPLOY-01, 22 passing tests in Run 42500427127); PayHere webhook verification rejects tampered amounts or signatures. Evidence: deploy/staging/test/release.test.mjs; deploy/staging/test/smoke.test.mjs; backend/src/payments/payhere-provider.spec.ts.

Required follow-up: Verify live staging rollback execution and signed container image provenance.

A09 Security Logging and Monitoring Failures

Security Logging and Monitoring Failures — PARTIALLY EVIDENCED: Secret, card, and SQL canary regression tests verify that AllExceptionsFilter never logs sensitive payloads (TC-SEC-01); payment and email providers emit structured failure events without raw provider payloads. Evidence: backend/src/common/filters/all-exceptions.filter.spec.ts; backend/src/payments/payhere-payments.service.spec.ts.

Required follow-up: Connect container logs to centralized log retention and configure security alerting on authentication/payment anomalies.

A10 Server-Side Request Forgery

Server-Side Request Forgery — PARTIALLY EVIDENCED: Room image helpers enforce an explicit HTTPS host allowlist and reject credentials or unsafe paths (TC-HW-03-01); payment return/redirect targets are restricted; gateway upstream origins are server-configured. Evidence: frontend/src/config/room-images.ts; frontend/tests/rooms.test.mjs; frontend/tests/payment.test.mjs.

Required follow-up: Upgrade Next.js to remediate Image Optimization advisories and enforce egress network policies in staging.

3. Manager Dashboard (MAD)

Repository: forever-hotel/manager-dashboard (+ forever-hotel/api-gateway f12aad6cb4, forever-hotel/websocket-service f12ef41ba9, forever-hotel/infra e3e17fcaac) | Branch: development | Tested revision: 8b2c63f459a93c217eb7cb502a2500e80181aa6e | CI date: 9 November 2026

Evidence: https://github.com/forever-hotel/manager-dashboard/actions/runs/42480400290, https://github.com/forever-hotel/manager-dashboard/actions/runs/42504148805, https://github.com/forever-hotel/api-gateway/actions/runs/42504067779, https://github.com/forever-hotel/websocket-service/actions/runs/42504249365

Dependency position: REMEDIATED IN CI — Backend npm audit --audit-level=high and frontend npm run audit:ci both passed with 0 high/critical vulnerabilities in Runs 42480400290 and 42504148805 after pinning transitive overrides (multer, body-parser, qs) in backend/package.json. Extracted shared repositories forever-hotel/api-gateway and forever-hotel/websocket-service also passed npm audit --audit-level=high with 0 high/critical vulnerabilities.

A01 Broken Access Control

Broken Access Control | PARTIALLY VERIFIED: Manager JWT/role guards, protected frontend route navigation, read-only operational views, and API Gateway route-level RBAC checks are verified across 534 MAD backend unit tests, 203 PostgreSQL/RabbitMQ integration tests, 8 Playwright E2E tests, and 39 API Gateway tests. Evidence: backend/src/common/security-boundaries.spec.ts; frontend/test/protection.test.ts; forever-hotel/api-gateway Run 42504067779.

Required follow-up: Execute full multi-role penetration testing across deployed gateway and subsystem endpoints.

A02 Cryptographic Failures

Cryptographic Failures | PARTIALLY VERIFIED: JWT signing/verification, bcrypt password hashing (cost >=12), and encrypted staff credential delivery are unit- and integration-tested in MAD and verified across central auth / WebSocket system checks (npm run test:system). Evidence: backend/src/auth/token.service.spec.ts; backend/src/staff/staff.spec.ts; Run 42480400290.

Required follow-up: Verify production TLS termination, vault secret management, and key rotation in deployed staging.

A03 Injection

Injection | PARTIALLY VERIFIED: Strict DTO validation, parameterized PostgreSQL queries, and CSV formula injection sanitization are verified in unit and PostgreSQL integration suites. Evidence: backend/src/promotions/promotions.spec.ts; backend/src/reports/reports.spec.ts.

Required follow-up: Perform automated DAST fuzzing against reporting, filtering, and search endpoints.

A04 Insecure Design

Insecure Design | PARTIALLY VERIFIED: Optimistic concurrency version checks, login lockout rules, atomic promotion and complaint workflows, and transactional outbox publication retries are verified in unit and PostgreSQL/RabbitMQ integration suites. Evidence: backend/test/promotions.e2e-spec.ts; backend/test/complaints.e2e-spec.ts.

Required follow-up: Obtain formal cross-subsystem threat-model sign-off.

A05 Security Misconfiguration

Security Misconfiguration | PARTIALLY VERIFIED: Frontend security response headers, strict environment validation, and infrastructure Compose/release configuration checks (19 passing tests in forever-hotel/infra Run 42501357369) are verified in CI. Evidence: frontend/test/security-headers.test.ts; backend/src/config/environment.spec.ts; forever-hotel/infra Run 42501357369.

Required follow-up: Inspect live staging reverse-proxy headers and container runtime privileges.

A06 Vulnerable and Outdated Components

Vulnerable and Outdated Components | REMEDIATED IN CI (PASS): Transitive high-severity advisories in body-parser, multer, and qs were remediated via package.json overrides; backend npm audit --audit-level=high, frontend npm run audit:ci, api-gateway npm audit --audit-level=high, and websocket-service npm audit --audit-level=high all passed in 9 November 2026 CI. Evidence: MAD Runs 42480400290 & 42504148805; API Gateway Run 42504067779; WebSocket Service Run 42504249365.

Required follow-up: Maintain continuous Dependabot and lockfile auditing up to final release tagging.

A07 Identification and Authentication Failures

Identification and Authentication Failures | PARTIALLY VERIFIED: Active-account checks, login lockout, JWT validation, mandatory first-password change, central auth system integration (npm run test:system), and WebSocket handshake authentication (36 passing tests in forever-hotel/websocket-service) are verified in CI. Evidence: backend/src/auth/auth.service.spec.ts; frontend/test/protection.test.ts; forever-hotel/websocket-service Run 42504249365.

Required follow-up: Verify cross-subsystem staff login and session revocation on deployed staging.

A08 Software and Data Integrity Failures

Software and Data Integrity Failures | PARTIALLY VERIFIED: CI enforces npm ci with locked dependencies, changed-code coverage gates (check-changed-coverage.test.mjs: 5 passed), build config verification (verify-build-config.test.mjs), and outbox publication confirmation/retry logic. Evidence: .github/workflows/ci.yml; backend/src/promotions/promotion-publication.spec.ts.

Required follow-up: Establish signed container image provenance for production deployment.

A09 Security Logging and Monitoring Failures

Security Logging and Monitoring Failures | PARTIALLY VERIFIED: Staff credential reset auditing, profile change auditing, log redaction, and safe error responses are verified in unit and integration tests. Evidence: backend/src/staff/staff-reset.spec.ts; backend/src/staff/staff-profiles.spec.ts.

Required follow-up: Verify centralized 12-month log retention and real-time alerting SLAs in staging.

A10 Server-Side Request Forgery

Server-Side Request Forgery | PARTIALLY VERIFIED: API Gateway routing and WebSocket upstream connections are bound to server-configured service origins validated in forever-hotel/api-gateway and forever-hotel/infra tests; no user-supplied outbound URL fetching is exposed. Evidence: forever-hotel/api-gateway Run 42504067779; forever-hotel/infra Run 42501357369.

Required follow-up: Execute targeted SSRF and egress-filtering verification in the deployed container network.

4. Front Desk System (FDS)

Repository: forever-hotel/front-desk | Branch: develop (QA evidence branch: feature/84-fds-final-qa-evidence) | Tested revision: 4b5ef57d4c4ce03c9ab2fe78f42b94eff96838cd (QA snapshot: e590326 / 1065617 / a6050dd) | CI date: 9 November 2026

Evidence: https://github.com/forever-hotel/front-desk/actions/runs/42506217082, https://github.com/forever-hotel/front-desk/actions/runs/42506217056, https://github.com/forever-hotel/front-desk/actions/runs/40530366600, https://github.com/forever-hotel/front-desk/actions/runs/40534533200

Dependency position: REMEDIATED IN CI — undici dev dependency upgraded to 8.12.2 (commit 1065617 and develop 4b5ef57d4c). Backend CI audit, frontend production-only audit, and full frontend npm audit all return 0 vulnerabilities.

A01 Broken Access Control

Broken Access Control — PARTIALLY EVIDENCED: JWT authentication, read/write RBAC enforcement, 401/403 HTTP E2E checks (worker role denied booking reads in TC-FDS-041), and local authenticated FDS-to-WKMS manual assignment permission checks (W04-B: 6 PASS) are verified across 143 HTTP E2E tests and 531 unit tests on develop (4b5ef57d4c). Source: backend/test/bookings-rbac.e2e-spec.ts; backend/test/check-in-rbac.e2e-spec.ts; backend/test/rooms-rbac.e2e-spec.ts; backend/test/audit-rbac.e2e-spec.ts.

Follow-up: Complete exhaustive endpoint-by-role negative matrix and public staging gateway review.

A02 Cryptographic Failures

Cryptographic Failures — NOT FULLY VERIFIED: JWT signature, expiry, and issuer verification are unit- and E2E-tested; checkout DTO validation blocks raw card numbers/CVV (TC-FDS-042). Central identity password hashing (bcrypt >=12) and staging HTTPS/TLS termination remain external to FDS CI. Source: backend/src/security/auth/jwt-principal.resolver.spec.ts; backend/test/folio-checkout-rbac.e2e-spec.ts.

Follow-up: Verify central auth credential storage and staging HTTPS/TLS certificates.

A03 Injection

Injection — PARTIALLY EVIDENCED: PostgreSQL repositories use parameterized queries exclusively (56 passing PostgreSQL integration tests on 4b5ef57d4c); DTO validation and plain-text sanitization strip unsafe input. Source: backend/src/reservations/repositories/postgres-booking.repository.ts; backend/src/security/sanitization/sanitize-plain-text.spec.ts.

Follow-up: Execute route-level injection and fuzzing scans against deployed staging.

A04 Insecure Design

Insecure Design — PARTIALLY EVIDENCED: Atomic PostgreSQL transactions with rollback on payment failure (TC-FDS-008), room conflict rejection (TC-FDS-011, TC-FDS-022), and database-enforced append-only audit triggers rejecting UPDATE/DELETE (TC-FDS-031, TC-FDS-032) are verified in CI and local Plan 02 (35 PASS). Source: backend/test/database/postgres-checkout.repository.integration-spec.ts; backend/test/database/audit-append-only.integration-spec.ts.

Follow-up: Obtain formal cross-service threat-model sign-off.

A05 Security Misconfiguration

Security Misconfiguration — PARTIALLY EVIDENCED: Joi startup validation enforces staging/production secrets, blocks wildcard CORS origins, and blocks DB_SYNCHRONIZE; Neon test branch schema & audit triggers (9/9 tables, 3/3 triggers) were verified in DDP-195. Source: backend/src/config/env.validation.spec.ts; evidence/ddp195_verification.md.

Follow-up: Reconcile Neon TypeORM migration history table and verify deployed staging headers.

A06 Vulnerable and Outdated Components

Vulnerable and Outdated Components — REMEDIATED IN CI (PASS): undici upgraded to 8.12.2 in commit 1065617 and merged into develop (4b5ef57d4c). Full frontend audit, production-only audit, and backend audit all report 0 vulnerabilities in Runs 40534533200, 42506217056, and 42506217082. Source: frontend/package-lock.json; backend/package-lock.json.

Follow-up: Confirm GitHub Dependabot alert closure on default branch.

A07 Identification and Authentication Failures

Identification and Authentication Failures — PARTIALLY EVIDENCED: Invalid, expired, and wrong-issuer JWTs are rejected on both HTTP routes and Socket.IO handshakes (TC-FDS-043); Phase D browser verification (8 PASS) confirmed realtime auth and reconnect behavior. Source: backend/src/security/auth/jwt-principal.resolver.spec.ts; backend/test/realtime.e2e-spec.ts.

Follow-up: Verify end-to-end central auth receptionist login, lockout, and session rotation.

A08 Software and Data Integrity Failures

Software and Data Integrity Failures — PARTIALLY EVIDENCED: CI runs npm ci with lockfiles, verifies multi-stage Docker builds (Run 42506217053), and enforces append-only audit log triggers in PostgreSQL; Phase C verified RabbitMQ broker restart and consumer recovery (5 PASS). Source: backend/test/database/audit-append-only.integration-spec.ts; .github/workflows/docker-image.yml.

Follow-up: Verify signed container artifact provenance in release deployment.

A09 Security Logging and Monitoring Failures

Security Logging and Monitoring Failures — PARTIALLY EVIDENCED: Check-in, checkout, room change, maintenance, and manual WKMS assignment operations write immutable audit records; LogRedactor strips PII and secrets from logs. Source: backend/src/security/redaction/log-redactor.spec.ts; backend/test/audit-rbac.e2e-spec.ts.

Follow-up: Configure centralized log shipping, retention, and alerting on repeated 401/403 events.

A10 Server-Side Request Forgery

Server-Side Request Forgery — PARTIALLY EVIDENCED: Outbound HTTP calls to WKMS use strictly configured service base URLs (wkms-http.client.spec.ts) and were exercised in local W04-B authenticated assignment verification (6 PASS). Source: backend/src/integrations/wkms/wkms-http.client.spec.ts.

Follow-up: Enforce outbound network allowlists and SSRF negative tests in deployed staging.

5. Food Ordering and Service Requests (FOSS)

Repository: forever-hotel/food-ordering | Branch: develop | Tested revision: 0d80cf5c66b566580927cb8fae1f7d549a15f03f (QA package commit: 9ac1e6f3df9f93ee76be6db479dc8c4bf6529328) | CI date: 9 November 2026

Evidence: https://github.com/forever-hotel/food-ordering/actions/runs/42490527447, https://github.com/forever-hotel/food-ordering/actions/runs/41833172660, documents/security/owasp-checklist.pdf & documents/security/owasp-notes.md (commit 9ac1e6f)

Dependency position: PASSING IN CI — Dedicated Dependency Security Scan job in Run 42490527447 (9 November 2026), Oxlint (240 backend files, 0 errors/warnings), and ESLint 9 (frontend, 0 errors/warnings) all passed with 0 high/critical vulnerabilities.

A01 Broken Access Control

Broken Access Control — PARTIALLY EVIDENCED: Guest endpoints require a valid signed Bearer JWT; RoomOwnershipGuard verifies that token roomNumber and bookingId match target resources, rejecting cross-room (Room 101 -> Room 102) and cross-booking IDOR attempts with 403 Forbidden (TC-FOSS-009, TC-FOSS-010); FDS checkout events immediately revoke active sessions (TC-FOSS-007). Source: backend/src/common/auth/room-ownership.guard.ts; backend/test/room-scoped-auth.e2e-spec.ts; backend/test/fds-checkout-session-revocation.e2e-spec.ts; frontend/tests/fui-02-room-isolation.test.ts.

Required follow-up: Coordinate with API Gateway to enforce IP rate limiting on /foss/guest-sessions/qr and execute multi-tenant penetration tests.

A02 Cryptographic Failures

Cryptographic Failures — PARTIALLY EVIDENCED: QR activation tokens are signed with HMAC-SHA256 (QR_HMAC_SECRET, TC-FOSS-002); guest JWTs are transmitted strictly via Authorization: Bearer headers; fetch-based SSE streaming avoids exposing tokens in EventSource URLs (TC-FOSS-041); Neon PostgreSQL enforces TLS 1.3. Source: backend/src/modules/guest-sessions/services/qr-activation.service.spec.ts; backend/test/qr-activation-lifecycle.e2e-spec.ts; frontend/tests/realtime-client-security.test.ts.

Required follow-up: Audit production API Gateway TLS cipher suites and confirm vault secret rotation.

A03 Injection

Injection — PARTIALLY EVIDENCED: TypeORM repositories use parameterized SQL queries exclusively; global NestJS ValidationPipe (whitelist: true, forbidNonWhitelisted: true) strips undeclared fields; free-text inputs are bounded (allergy notes <=300 chars in TC-FOSS-022, complaint and service-request descriptions <=500 chars); sanitizePlainText strips HTML/script tags. Source: backend/src/modules/food-orders/dto/create-order.dto.ts; backend/test/api-validation-and-errors.e2e-spec.ts; frontend/tests/pricing-and-quantity.test.ts.

Required follow-up: Run automated OWASP ZAP baseline API scan against containerized backend routes.

A04 Insecure Design

Insecure Design — PARTIALLY EVIDENCED: High-entropy Idempotency-Key headers prevent duplicate orders and double-billing (TC-FOSS-025); 10-minute cancellation cutoff and kitchen PREPARING lock-in are enforced on backend (TC-FOSS-030..032); server recalculates order totals from authoritative catalog prices in integer minor units (TC-FOSS-023, TC-FOSS-024); cart quantity is capped at 20 per line item (TC-FOSS-019). Source: backend/src/modules/food-orders/food-orders.service.spec.ts; backend/test/food-orders.e2e-spec.ts; frontend/tests/cart.test.ts.

Required follow-up: Complete architectural review for PostgreSQL transactional outbox (docs/change-requests/CR-outbox-foss.md).

A05 Security Misconfiguration

Security Misconfiguration — PARTIALLY EVIDENCED: class-validator bootstrap validation (env.validation.ts) rejects missing config; HealthService and assertApprovedDatabaseIdentity block test suites from running against development/production Neon branches and enforce synchronize: false; frontend blocks DATA_MODE=demo in production; HttpExceptionFilter prevents stack trace disclosure. Source: backend/src/config/env.validation.ts; backend/src/health/health.service.spec.ts; backend/src/database/guards/assert-approved-database-identity.spec.ts; backend/src/common/filters/http-exception.filter.ts.

Required follow-up: Verify gateway security headers (CSP, HSTS) and non-root container execution in staging.

A06 Vulnerable and Outdated Components

Vulnerable and Outdated Components — PARTIALLY EVIDENCED (CI SCAN PASS): Dependency Security Scan job in GitHub Actions Run 42490527447 passed with 0 high/critical vulnerabilities; Oxlint (240 backend files) and ESLint 9 (frontend) pass with 0 errors/warnings; lockfiles are strictly pinned. Source: backend/package.json; frontend/package.json; GitHub Actions Run 42490527447.

Required follow-up: Maintain continuous Dependabot monitoring across transitive dev dependencies.

A07 Identification and Authentication Failures

Identification and Authentication Failures — PARTIALLY EVIDENCED: QR slip activation validates booking reference, room number, and high-entropy access code (TC-FOSS-001, TC-FOSS-002); sessions enforce a 24h TTL (SESSION_TTL_HOURS=24, TC-FOSS-006) and immediate revocation on FDS checkout (TC-FOSS-007) or SSE SESSION_REVOKED events (TC-FOSS-044); frontend partitions demo and API tokens cleanly (TC-FOSS-011, TC-FOSS-012). Source: backend/src/modules/guest-sessions/guest-sessions.service.ts; backend/test/guest-sessions.e2e-spec.ts; frontend/tests/auth-lifecycle-isolation.test.ts.

Required follow-up: Verify gateway brute-force rate limiting on /foss/guest-sessions/qr.

A08 Software and Data Integrity Failures

Software and Data Integrity Failures — PARTIALLY EVIDENCED: RabbitMQ inter-service messages require HMAC-SHA256 SignedEventEnvelope verification (TC-FOSS-027, TC-FOSS-045); event ID deduplication discards replayed messages (TC-FOSS-046); malformed/poisoned payloads route to forever.hotel.dlq (TC-FOSS-047); TypeORM enforces synchronize: false. Source: backend/src/integrations/contracts/signed-event-envelope.spec.ts; backend/src/messaging/rabbitmq-consumer.service.spec.ts; backend/test/rabbitmq-live-integration.e2e-spec.ts.

Required follow-up: Enforce RabbitMQ TLS and per-service vhost/credential isolation in production.

A09 Security Logging and Monitoring Failures

Security Logging and Monitoring Failures — PARTIALLY EVIDENCED: CorrelationMiddleware propagates X-Correlation-ID across requests; LogSanitizerUtil masks Bearer tokens, passwords, and guest PII to [REDACTED] before logging; security lifecycle events (QR activation, revocation, order cancellation) emit structured logs. Source: backend/src/common/middleware/correlation.middleware.spec.ts; backend/src/common/logging/log-sanitizer.util.spec.ts.

Required follow-up: Integrate container stdout streams with centralized hotel SIEM/Loki log aggregation and alerting.

A10 Server-Side Request Forgery

Server-Side Request Forgery — PARTIALLY EVIDENCED: Outbound HTTP adapters for FDS, KMS, WKMS, and MAD use strictly preconfigured environment base URLs and hardcoded path templates without accepting user-supplied URLs or following redirects. Source: backend/src/integrations/internal-services/booking/adapters/real-booking.adapter.ts; backend/src/integrations/internal-services/kms/adapters/real-kms.adapter.ts; backend/src/integrations/internal-services/wkms/adapters/real-wkms.adapter.ts; backend/src/integrations/internal-services/mad/adapters/real-mad-complaint.adapter.ts.

Required follow-up: Enforce container egress policies blocking access to cloud metadata endpoints (169.254.169.254).

6. Kitchen Management System (KMS)

Repository: forever-hotel/kitchen-management | Branch: develop | Tested revision: 0eaf5ab9b071ae7e5e3478cf30a27fe819db35dc (PR #106 & PR #103) | CI date: 9 November 2026

Evidence: https://github.com/forever-hotel/kitchen-management/actions/runs/42645080201

Dependency position: PASSING IN CI — Both backend and frontend npm run security:audit (npm audit --omit=dev --audit-level=high) passed with 0 vulnerabilities in Run 42645080201 alongside 837 passing automated unit, E2E, and frontend tests.

A01 Broken Access Control

Broken Access Control — PARTIALLY EVIDENCED: Between 10 October and 9 November 2026 (commit 0eaf5ab, Run 42645080201), KMS expanded from 2 scaffold E2E suites to 10 passing E2E suites (58 passing E2E tests) and 54 backend unit suites (234 passing unit tests) covering kitchen order creation/reading/state transitions and menu item/category write operations. Cross-service gateway RBAC is enforced in forever-hotel/api-gateway (39 passing tests).

Remaining verification: Execute end-to-end negative RBAC penetration tests across all kitchen staff and manager roles on deployed staging.

A02 Cryptographic Failures

Cryptographic Failures — PARTIALLY EVIDENCED: Database configuration tests verify managed PostgreSQL SSL and certificate verification settings (database.e2e-spec.ts); central JWT verification is handled at the API Gateway / auth boundary.

Remaining verification: Verify staging TLS certificates, broker transport encryption, and secret rotation.

A03 Injection

Injection — PARTIALLY EVIDENCED: Joi environment validation, NestJS DTO validation across menu and order write endpoints (menu-item-write.e2e-spec.ts, menu-category-write.e2e-spec.ts, orders-create.e2e-spec.ts), allergy note safety validation (allergy-safety.e2e-spec.ts), and parameterized TypeORM repository queries are verified in Run 42645080201.

Remaining verification: Execute hostile SQL/XSS fuzzing against operational API boundaries.

A04 Insecure Design

Insecure Design — PARTIALLY EVIDENCED: Order state transition guards (orders-transition.e2e-spec.ts), meal ordering window enforcement (ordering-window.e2e-spec.ts), allergy safety persistence/visibility (allergy-safety.e2e-spec.ts), and positive quantity/price domain rules are verified across 234 backend unit tests, 58 E2E tests, and 373 frontend Jest tests.

Remaining verification: Verify live cross-service FOSS-KMS-WKMS concurrency and physical KOT printer failover.

A05 Security Misconfiguration

Security Misconfiguration — PARTIALLY EVIDENCED: Startup environment validation, disabled automatic schema synchronization, and managed PostgreSQL SSL checks pass in CI.

Remaining verification: Verify production CORS allowlists, error disclosure handling, and container hardening in staging.

A06 Vulnerable and Outdated Components

Vulnerable and Outdated Components — PARTIALLY EVIDENCED (PROD AUDIT PASS): Both backend and frontend npm run security:audit steps passed with 0 production high/critical vulnerabilities in GitHub Actions Run 42645080201.

Remaining verification: Audit full development dependency trees before final release tagging.

A07 Identification and Authentication Failures

Identification and Authentication Failures — PARTIALLY EVIDENCED: Frontend authentication state and kitchen role workflows are tested across 59 frontend Jest suites (373 passing tests) and API Gateway auth tests; live central-auth kitchen staff login E2E remains pending staging integration.

Remaining verification: Verify kitchen staff login, token expiry, session revocation, and lockout against live central auth.

A08 Software and Data Integrity Failures

Software and Data Integrity Failures — PARTIALLY EVIDENCED: CI enforces npm ci with committed lockfiles, lint, build, and 665 automated tests in Run 42645080201.

Remaining verification: Verify signed RabbitMQ event envelopes and immutable container image provenance in staging.

A09 Security Logging and Monitoring Failures

Security Logging and Monitoring Failures — PARTIALLY EVIDENCED: Order transition and kitchen operational state changes are tracked in application services; centralized SIEM log retention and security alerting remain unverified.

Remaining verification: Add dedicated security audit log redaction tests and staging monitoring alerts.

A10 Server-Side Request Forgery

Server-Side Request Forgery — PARTIALLY EVIDENCED: KMS connects only to preconfigured PostgreSQL and RabbitMQ endpoints validated at startup; no user-controlled outbound URL fetching exists.

Remaining verification: Enforce container egress network policies in staging.

7. Worker Management System (WKMS)

Repository: forever-hotel/worker-management | Branch: develop | Tested revision: 1a33059c0005752ca709ca91ab11067dc6cff55a (PR #75 82f458005b; Oct 25 baseline: 0f91f1c9d6390c80c9f12f82b834fee9bf374104) | CI date: 9 November 2026

Evidence: https://github.com/forever-hotel/worker-management/actions/runs/42504698971, https://github.com/forever-hotel/worker-management/actions/runs/42504970394, https://github.com/forever-hotel/worker-management/actions/runs/42496517266

Dependency position: PASSING IN CI — Backend and frontend production high-threshold npm audits both passed with 0 vulnerabilities in Runs 42504698971 and 42504970394 alongside 649 passing automated tests (400 backend, 249 frontend) and >80% enforced whole-application branch and line coverage.

A01 Broken Access Control

Broken Access Control — PARTIALLY EVIDENCED: Worker role JWT guards, task claim ownership checks, and receptionist manual assignment authorization (verified in WKMS unit suites and FDS-to-WKMS local W04-B verification: 6 PASS) are tested across 400 backend and 249 frontend tests on develop (1a33059c00). Evidence: backend/src/auth/guards/worker-role.guard.ts; backend/src/database/repositories/task.repository.spec.ts.

Required follow-up: Execute full cross-role E2E matrix on deployed staging.

A02 Cryptographic Failures

Cryptographic Failures — PARTIALLY EVIDENCED: bcrypt password verification, signed JWT worker authentication, and Socket.IO token expiry enforcement (wkms-realtime.gateway.spec.ts, 94.91% line / 90.00% branch coverage) are verified in CI. Evidence: backend/src/auth/auth.service.spec.ts; backend/src/realtime/wkms-realtime.gateway.spec.ts.

Required follow-up: Verify staging HTTPS/WSS TLS certificates and secret rotation.

A03 Injection

Injection — PARTIALLY EVIDENCED: Parameterized pg SQL queries and strict RabbitMQ message contract validators (checkout-completed.validator.spec.ts, order-ready.validator.spec.ts) reject malformed payloads. Evidence: backend/src/database/repositories/task.repository.ts; backend/src/messaging/contracts/checkout-completed.validator.spec.ts.

Required follow-up: Execute malicious SQL and AMQP payload fuzzing in staging.

A04 Insecure Design

Insecure Design — PARTIALLY EVIDENCED: Row-level locking for the max-three-claimed-tasks rule, RabbitMQ message deduplication, and transactional escalation outbox dispatching (verified in unit tests and FDS Phase B local boundary run: 3 PASS) prevent double-claiming and lost escalations. Evidence: backend/src/database/repositories/task.repository.spec.ts; backend/src/messaging/outbox/outbox-dispatcher.service.spec.ts.

Required follow-up: Complete formal threat-model sign-off and live 15-minute escalation timer staging test.

A05 Security Misconfiguration

Security Misconfiguration — PARTIALLY EVIDENCED: Joi environment validation, Socket.IO origin restrictions, and frontend public build configuration validation (enforced in CI workflow) prevent unsafe defaults. Evidence: backend/src/config/env.validation.spec.ts; backend/src/realtime/wkms-realtime.gateway.ts; .github/workflows/ci.yml.

Required follow-up: Configure production origin allowlists and inject release public URLs in deployment secrets.

A06 Vulnerable and Outdated Components

Vulnerable and Outdated Components — PARTIALLY EVIDENCED (PROD AUDIT PASS): Backend and frontend production dependency audits passed with 0 vulnerabilities in Runs 42504698971 and 42504970394.

Required follow-up: Archive full-tree npm audit JSON alongside tagged release artifacts.

A07 Identification and Authentication Failures

Identification and Authentication Failures — PARTIALLY EVIDENCED: Inactive worker rejection, non-WORKER role denial, JWT validation, and Socket.IO handshake authentication are tested in CI. Evidence: backend/src/auth/auth.service.spec.ts; backend/src/realtime/wkms-realtime.gateway.spec.ts.

Required follow-up: Verify login rate-limiting/lockout and central auth compatibility on staging.

A08 Software and Data Integrity Failures

Software and Data Integrity Failures — PARTIALLY EVIDENCED: CI enforces npm ci, >=80% whole-app branch/line coverage gates, Docker image build verification (Run 42504970394), event schema version validation, and outbox retry persistence (verified across broker restart in FDS Phase C: 5 PASS). Evidence: backend/src/messaging/contracts/order-ready.validator.spec.ts; .github/workflows/ci.yml.

Required follow-up: Configure release environment URLs for the immutable image publishing job and verify image signing.

A09 Security Logging and Monitoring Failures

Security Logging and Monitoring Failures — PARTIALLY EVIDENCED: Task lifecycle transitions, manual assignments, and escalation events are logged in service and outbox layers. Evidence: backend/src/tasks/task.service.ts; backend/src/tasks/task-escalation.service.spec.ts.

Required follow-up: Connect WKMS logs to centralized SIEM retention and incident alerting.

A10 Server-Side Request Forgery

Server-Side Request Forgery — PARTIALLY EVIDENCED: Database and RabbitMQ connections use server-configured environment URLs only; WKMS does not fetch user-supplied URLs. Evidence: backend/src/config/env.validation.ts; backend/src/messaging/rabbitmq/rabbitmq.config.ts.

Required follow-up: Verify container network egress restrictions in staging.

8. Outstanding security acceptance

- Upgrade the remaining full-tree dependencies reported in the Hotel Website raw audit (Next.js 16.4.3 and NestJS/Express transitive overrides matching Manager Dashboard) and archive clean npm audit --json outputs for all repositories at the final release tag.
- Execute an integrated staging authorization and IDOR penetration test across forever-hotel/api-gateway, forever-hotel/websocket-service, and all six subsystem backends covering guest, worker, chef, receptionist, and manager roles.
- Verify deployed staging HTTPS/WSS TLS certificates, HSTS/CSP response headers, CORS origin allowlists, RabbitMQ broker TLS/vhost isolation, and container egress policies (blocking cloud metadata IP 169.254.169.254).
- Complete architectural sign-off and staging verification for the FOSS PostgreSQL transactional outbox (CR-outbox-foss.md) and Neon TypeORM migration history reconciliation in FDS (DDP-195).
- Obtain dated security reviewer sign-off and residual-risk disposition before certifying production OWASP compliance.